Technische Resilienz I

Vorlesungsskript · Sitzung 7 · Grundlagen der Resilienz

Prof. Dr. Dirk Loomans

29. September 2026

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Die mit „Hinweis zur Aktualität“ und „Ergänzung zur Vorlesung“ markierten Kästen sowie die Abbildungen wurden bei der Überführung ins Quarto-Projekt ergänzt. Der übrige Text entspricht dem Skript aus dem Wintersemester 2025/26; korrigiert wurden nur Tipp- und Umbruchfehler.

Kapitel 1 – Einführung und Zielsetzung der Sitzung

Technische Resilienz bildet die Grundlage für die Fähigkeit einer Organisation, IT-Systeme und digitale Geschäftsprozesse trotz Störungen, Angriffen oder Ausfällen aufrechtzuerhalten oder zeitnah wiederherzustellen. Während die vorherigen Sitzungen den organisatorischen Rahmen beleuchtet haben – Rollen, Verantwortlichkeiten und Kommunikationswege –, richtet sich der Fokus dieser Sitzung auf die **technischen Mechanismen**, die das Fundament einer widerstandsfähigen IT-Landschaft darstellen.

Cyberangriffe wie Ransomware, sabotierte Cloud-Konfigurationen, defekte Speichersysteme oder versehentliche Datenlöschungen gehören zu den häufigsten Ursachen schwerwiegender IT-Störungen. Ein wesentliches Merkmal moderner Angriffskampagnen ist die gezielte Vernichtung oder Manipulation von Backups, um die Wiederherstellungsfähigkeit zu sabotieren. In diesem Kontext ist technische Resilienz nicht nur ein IT-Thema, sondern eine **Überlebensvoraussetzung** für Organisationen aller Größen und Branchen.

Diese Sitzung hat zwei grundlegende didaktische Ziele:

1. **Verstehen:**

   Die Studierenden sollen die Bedeutung und Funktionsweise technischer Resilienzmaßnahmen erkennen. Dazu gehören insbesondere Backup-Strategien, Wiederanlaufmechanismen (Disaster Recovery, DR) und strukturiertes Testen (Notfalltests).

   Der Fokus liegt darauf, zu verstehen, warum technische Resilienz mehr ist als „ein Backup haben“.

2. **Bewerten und Anwenden:**

   Die Studierenden sollen typische Backup- und DR-Strategien vergleichen, Risiken in der Praxis identifizieren und die Rolle von Tests für die tatsächliche Wiederherstellbarkeit beurteilen können. Damit werden sie befähigt, technische Resilienzkonzepte für reale Umgebungen zu entwerfen oder zu evaluieren.

Die zentrale Fragestellung, die diese Sitzung prägt, lautet:

„Wie stellen wir sicher, dass wir Systeme und Daten auch unter worst-case-Bedingungen zuverlässig wiederherstellen können?“

Diese Frage bildet den roten Faden der Sitzung und verbindet die drei technischen Säulen, die im Folgenden detailliert behandelt werden: **Backups, Disaster Recovery und Notfalltests.**

Kapitel 2 – Warum Backups essenziell für Resilienz sind

Backups sind die zentrale technische Absicherung gegen den Verlust oder die Korruption von Daten. Sie bilden die **letzte Verteidigungslinie** einer Organisation. Während Firewalls, Intrusion Detection Systeme oder Endpoint Protection Angriffe verhindern oder abschwächen sollen, greifen Backups erst dann, wenn alle vorgelagerten Schutzmechanismen versagt haben. Damit entscheiden Backups häufig über die **Existenzfähigkeit** einer Organisation nach einem gravierenden Vorfall.

2.1 Die Rolle von Backups im Resilienzkonzept

Backups stellen einen historischen Zustand eines IT-Systems wieder her – unabhängig von dessen aktuellem Zustand. Sie erlauben es, Zeitpunkte zurückzuspringen, an denen Daten intakt waren, und sind damit im Kern ein **Reversionsmechanismus** gegen Datenverlust. In der Resilienzarchitektur ist dies essenziell, da Fehlerquellen vielfältig sind:

- **Cyberangriffe:**

  Insbesondere Ransomware hat sich gezielt darauf spezialisiert, Backups anzugreifen, zu verschlüsseln oder zu löschen. Moderne Kampagnen versuchen häufig, Backups auszuschalten, bevor produktive Daten verschlüsselt werden.

- **Menschliches Fehlverhalten:**

  Fehlkonfigurationen, versehentliches Löschen von Dateien oder falsche Skriptausführungen zählen zu den häufigsten Ursachen von Datenverlusten.

- **Technische Defekte:**

  Speicherfehler, RAID-Ausfälle, Controller-Defekte oder Festplattensterben führen oft zu logischen oder physikalischen Schäden.

- **Softwarefehler:**

  Datenbankinkonsistenzen, Applikationsfehler oder korrupte Dateien können zu unbrauchbaren Datenbeständen führen.

2.2 Backups als Schutz vor modernen Angriffen

Backups sind keine „klassische IT-Aufgabe“ mehr, sondern ein **zentrales Security-Control**.

Aktuelle Studien (z. B. ENISA Threat Landscape) zeigen, dass Ransomware-Gruppen verstärkt versuchen:

- Backup-Repositories zu kompromittieren
- Snapshots zu löschen
- Shadow Copies zu entfernen
- Backup-Server zu übernehmen
- Zugangsdaten von Backup-Administratoren zu stehlen

Dies hat das Backup-Paradigma verändert: Backups müssen heute **manipulationssicher, isoliert und wiederherstellbar** sein.

Damit wird deutlich: Resilienz entsteht nicht allein durch die Existenz von Backups, sondern durch deren Fähigkeit, **im Ernstfall zu überleben**.

2.3 Organisatorische Auswirkungen unzureichender Backups

Unternehmen, die nach einem Vorfall keine funktionierenden Backups haben, stehen oft vor existenziellen Problemen:

- Wiederaufbaukosten und Umsatzausfälle
- Vertrags- und Haftungsrisiken
- Reputationsschäden
- Betriebsunterbrechungen über Wochen oder Monate
- komplette Datenverluste

Gerade für Erstsemester ist hier wichtig zu verstehen: Resilienz ist kein theoretisches Ziel, sondern eine Frage der **Überlebensfähigkeit** einer Organisation.

Backups machen Recovery möglich – ohne sie bleibt nur Neuaufbau.

2.4 Fazit

Backups sind das technische Pendant zur Versicherung – mit dem Unterschied, dass Backups im Ernstfall wirklich helfen müssen. Backups sind essenziell für jede Resilienzstrategie, aber sie sind nur dann wirksam, wenn sie sicher, isoliert und regelmäßig getestet sind. Sie sind nicht Ersatz für technische Schutzmechanismen – aber sie sind der Garant dafür, dass Fehler, Angriffe und Defekte nicht dauerhaft wirken.

Kapitel 3 – Grundlagen: Backup vs. Archiv vs. Redundanz

In vielen Organisationen werden Begriffe wie **Backup**, **Archiv** und **Redundanz** synonym verwendet.

Diese Gleichsetzung ist jedoch gefährlich, da die drei Konzepte völlig unterschiedliche Ziele verfolgen.

Eine zentrale Voraussetzung technischer Resilienz ist daher das korrekte Verständnis **dieser Begriffe** und ihrer jeweiligen Rolle in der Gesamtarchitektur.

3.1 Backup – Wiederherstellung vergangener Zustände

Ein Backup ist eine **Kopie von Daten oder Systemen zu einem bestimmten Zeitpunkt**, die zur Wiederherstellung nach einem Verlust oder einer Beschädigung dient.

Zweck:

- Wiederherstellung nach Cyberangriff
- Wiederherstellung nach Fehlbedienung
- Rückkehr zu funktionierenden Systemzuständen
- Schutz gegen Datenkorruption

Merkmale:

- zeitpunktbezogen („Point-in-Time“)
- oft getrennt vom produktiven System
- Wiederherstellung geht vor Performance

Backups sind nicht für langfristige Aufbewahrung oder Ausfallsicherheit gedacht – ihr einziges Ziel ist die **Wiederherstellbarkeit**.

3.2 Archiv – Langzeitaufbewahrung und Compliance

Ein Archiv dient der **dauerhaften, unveränderbaren Speicherung von Daten**, oft über gesetzlich definierte Zeiträume (z. B. zehn Jahre für steuerrelevante Unterlagen in Deutschland).

Zweck:

- rechtliche Aufbewahrungspflichten
- Revision und Nachvollziehbarkeit
- Schutz vor unabsichtlicher Löschung
- Dokumentationspflichten

Merkmale:

- unveränderbar (z. B. WORM – Write Once, Read Many)
- Dateiformate oft langfristig stabil
- niedrige Zugriffsfrequenz
- kein Ersatz für Backups, da meist keine vollständigen Systemzustände archiviert werden

Archivanwendungen sind sicherheitsrelevant – aber nicht geeignet, gesamte Systeme oder deren Konfigurationen wiederherzustellen.

3.3 Redundanz – Kontinuierliche Verfügbarkeit im Betrieb

Redundanz bedeutet, Komponenten **parallel** oder **doppelt** zu betreiben, um Ausfälle eines Elements im laufenden Betrieb abzufangen.

Beispiele:

- RAID-Level (z. B. RAID 1, RAID 5, RAID 10)
- Redundante Netzteile oder Kühlung
- Clusterfähige Server
- Failover-Paare
- hochverfügbare Storage-Systeme

Zweck:

- Minimierung von Downtime
- Fortführung des Betriebs ohne Unterbrechung
- Kompensation von Hardwarefehlern

Wichtig: Redundanz löst keine logischen Probleme (z. B. versehentlich gelöschte Dateien, korrupte Datenbanken oder Ransomware). Redundante Systeme spiegeln Fehler oft nur schneller.

3.4 Typische Missverständnisse in der Praxis

Viele Unternehmen sind in ernsthaften Recovery-Szenarien gescheitert, weil sie Annahmen getroffen haben wie:

- „Wir haben RAID, also haben wir Backups."
- „Wir archivieren alles, das reicht als Backup."
- „Unsere Cloud repliziert automatisch alles."

- „Snapshots sind doch Backups."

Diese Annahmen führen im Ernstfall zu katastrophalen Konsequenzen. Resiliente Organisationen trennen die Begriffe strikt und optimieren **jede Dimension separat**.

3.5 Fazit

Backups sichern Daten. Archive sichern Dokumentation. Redundanz sichert Verfügbarkeit. Keine dieser Maßnahmen kann die anderen ersetzen. Die drei Konzepte sind komplementäre Bausteine eines Resilienzsystems – und nur ihr Zusammenwirken schafft echte technische Stabilität.

Kapitel 4 – Backup-Strategien und Regeln (3-2-1-1-0)

Backup-Strategien definieren **wie**, **wo** und **in welcher Struktur** Daten vorgehalten werden, um im Notfall wiederhergestellt werden zu können. Eine wirksame Strategie berücksichtigt technische, organisatorische und sicherheitsrelevante Aspekte. Die bekannteste und bis heute zentrale Leitlinie ist die **3-2-1-Regel**, die in den letzten Jahren durch moderne Varianten (3-2-1-1-0) weiterentwickelt wurde.

4.1 Die klassische 3-2-1-Regel

Die 3-2-1-Regel gilt seit den 2000er-Jahren als Best Practice im Backup-Design und wird von zahlreichen Institutionen wie dem *US-CERT*, *NIST* und großen Storage-Herstellern (z. B. Veeam, IBM, Dell) empfohlen.

Sie lautet:

- **3 Kopien der Daten**

  Eine primäre Kopie + mindestens zwei unabhängige Backups.

- **2 unterschiedliche Speichermedien**

  Beispielsweise Disk + Tape oder lokaler Storage + Cloud.

- **1 Kopie außerhalb des Standorts (Offsite)**

  Schutz gegen physische Schäden, Feuer, Wasser, Einbruch, Sabotage.

Die Regel adressiert insbesondere Risiken wie lokale Katastrophen, Ransomware und Storage-Ausfälle.

4.2 Die moderne 3-2-1-1-0-Regel

Cyberangriffe haben gezeigt, dass Offsite allein nicht mehr ausreicht. Angreifer greifen gezielt Backup-Infrastrukturen an. Moderne Resilienz verlangt zwei weitere Dimensionen:

- **+1** → *Eine Kopie muss immutable oder air-gapped sein.* Das bedeutet, sie kann nicht verändert, gelöscht oder überschrieben werden – auch nicht durch kompromittierte Administratoren oder Malware.
- **+0** → *Zero Errors in Recovery Tests.* Ein Backup ist nur dann ein Backup, wenn der Restore erfolgreich getestet wurde. Ohne Restore-Test ist ein Backup wertlos.

Diese Erweiterung spiegelt die Erkenntnisse aus heutigen Ransomware-Kampagnen, bei denen Angreifer häufig zuerst Backups angreifen oder manipulieren.

4.3 Air-Gapped Backups

Air-Gaps isolieren Backups **physisch** oder **logisch** vom Netzwerk:

- **Physisch:**

  Medien wie Tape werden ausschließlich zur Sicherung verbunden und danach physisch getrennt.

- **Logisch:**

Systeme sind nur über kontrollierte Mechanismen erreichbar (z. B. zeitgesteuert, dedizierte One-Way-Links).

Air-Gapped Backups sind besonders sicher, aber erfordern organisatorische Disziplin.

4.4 Immutable Backups

Immutable Backups sind schreibgeschützt und können für definierte Zeiträume **nicht verändert werden**.

Sie basieren meist auf:

- WORM-Technologien („Write Once, Read Many“)
- glazialen Cloud-Speichern (AWS Glacier Vault Lock, Azure Immutable Blob)
- Dateisystemen mit unveränderbaren Snapshots (z. B. ZFS, NetApp SnapLock)

Diese Methode schützt effektiv vor Löschaktionen, Ransomware und kompromittierten Admin-Konten.

4.5 Medienvielfalt und Risiko der Homogenität

Backups auf identischen Speichermedien (z. B. zwei Festplatten im gleichen System) schützen kaum vor:

- Firmwarefehlern
- Seriendefekten
- Bränden
- Überspannung
- Angriffen auf das Storage-System selbst

Resiliente Systeme bauen daher immer auf **Medienvielfalt**.

4.6 Retention-Strategien

Eine Backup-Strategie ist unvollständig ohne klare Retention-Definitionen:

- tägliche Retention (kurzfristig)
- wöchentliche Retention
- monatliche / jährliche Retention
- gesetzliche Aufbewahrungsfristen

Typischer Fehler: Retention-Policies sind inkonsistent oder über Jahre gewachsen.

4.7 Fazit

Die 3-2-1-1-0-Regel ist kein traditionelles IT-Paradigma, sondern eine moderne Security-Anforderung.
Ein robustes Backup-Design basiert nicht nur auf Redundanz, sondern auf Isolation, Medienvielfalt, Unveränderbarkeit und konsequent getesteter Wiederherstellbarkeit.

Kapitel 5 – Backup-Typen und Anwendungsfälle

Backup-Typen unterscheiden sich darin, wie viele Daten gesichert werden, wie lange die Sicherung dauert, wie viel Speicherplatz benötigt wird und wie schnell eine Wiederherstellung erfolgen kann. Ein grundlegendes Verständnis dieser Typen ist essenziell, um Backup-Strategien anwendungs- und risikogerecht gestalten zu können.

5.1 Vollbackup

Ein Vollbackup sichert **alle** ausgewählten Daten, unabhängig von früheren Sicherungen.

Eigenschaften:

- vollständig und einfach nachvollziehbar
- längere Sicherungsdauer
- hoher Speicherbedarf
- schneller Restore, da alle Daten in einem Backup enthalten sind

Anwendungsfälle:

- initiale Basis-Sicherung („Seed Backup“)
- kritische Systeme mit moderater Datenmenge
- regelmäßige Vollbackups als Referenzpunkte (z. B. wöchentlich)

Vollbackups bilden die Grundlage jeder Backup-Kette, sind aber allein selten effizient.

5.2 Inkrementelles Backup

Ein inkrementelles Backup speichert **nur die Änderungen** seit dem **letzten Backup**, egal welchen Typs.

Vorteile:

- sehr schnell
- benötigt wenig Speicher
- ideal für häufige Sicherungen (z. B. alle 15 Minuten)

Nachteile:

- Restore kann langsam sein, da mehrere Kettenglieder benötigt werden
- besonders anfällig, wenn ein Teil der Kette beschädigt ist

Anwendung: Dynamische Systeme, Datenbanken, Virtualisierungsumgebungen, Cloud-Workloads.

5.3 Differenzielles Backup

Ein differenzielles Backup speichert alle Änderungen **seit dem letzten Vollbackup**.

Vorteile:

- größer als inkrementell, aber kleiner als voll
- Restore schneller als bei inkrementellen Backups (es werden nur Vollbackup + letztes differenzielles benötigt)

Nachteile:

- wächst mit der Zeit
- belastet Speicher mehr als inkrementelle Backups

Differenzielle Backups eignen sich für Umgebungen mit klar definierten Backup-Fenstern (z. B. wöchentliche Vollbackups + tägliche differenzielle Backups).

5.4 Snapshots – hilfreich, aber kein Backup

Snapshots sind **zeitpunktgenaue Abbilder** von Systemzuständen auf Storage- oder Hypervisor-Ebene.

Vorteile:

- sehr schnell

- minimaler zusätzlicher Speicherbedarf
- ideal für kurzfristige Rollbacks

Nachteile:

- abhängig vom Host- oder Storage-System
- bei Schäden am Storage (z. B. Ransomware, Hardwarefehler) oft ebenfalls betroffen
- häufig überschätzt

Snapshots sind wertvolle Ergänzungen, ersetzen aber **niemals** ein echtes Backup. Sie sind Teil einer **Verfügbarkeitsstrategie**, nicht der eigentlichen Backup-Resilienz.

5.5 Cloud-native Backups

In Cloud-Umgebungen (AWS, Azure, GCP) existieren eigene Backup-Mechanismen:

- objektbasierte Versionierung (S3 Versioning, Azure Blob Versions)
- Datenbank-spezifische Mechanismen (z. B. RDS Snapshots)
- regionenübergreifende Replikation
- Backup-as-a-Service

Wichtig: Cloud-native Backups unterliegen ebenfalls dem **Shared-Responsibility-Modell**.

Die Cloud schützt die Infrastruktur – aber **Daten** müssen weiterhin vom Kunden gesichert werden.

5.6 Mischung der Backup-Typen

Robuste Backup-Strategien basieren fast immer auf einer Kombination:

- wöchentliches Vollbackup
- tägliches differenzielles Backup
- inkrementelle Backups alle 2 Stunden
- Snapshots vor kritischen Updates
- monatliche Archive
- immutable Kopie offsite

Diese Kombination entsteht nicht aus Tradition, sondern aus einem **risikobasierten Ansatz**.

5.7 Fazit

Backup-Typen sind Werkzeuge. Resilienz entsteht durch ihre intelligente Kombination.

Die passende Mischung hängt von Datenvolumen, Risikobereitschaft, Performance-Anforderungen, RTO/RPO-Zielen und Budget ab.

Kapitel 6 – Backup-Architekturen (On-Prem, Cloud, Hybrid)

Backup-Architekturen definieren, **wo** Backups gespeichert, **wie** sie übertragen und **unter welchen Bedingungen** sie wiederhergestellt werden können. Moderne Organisationen nutzen zunehmend hybride Ansätze, die lokale und cloudbasierte Komponenten miteinander verbinden. Jede Architekturform bringt eigene Stärken, Schwächen und Sicherheitsanforderungen mit sich.

6.1 On-Premises Backup-Architekturen

Bei On-Prem-Architekturen befindet sich die gesamte Backup-Infrastruktur im eigenen Rechenzentrum.

Vorteile:

- vollständige Kontrolle über Hardware, Software und Sicherheit
- geringe Latenzen bei Backup und Restore
- hohe Bandbreiten intern verfügbar
- keine externen Abhängigkeiten

Herausforderungen:

- hohe Investitionskosten
- physische Risiken (Feuer, Wasser, Einbruch, Sabotage)
- Disaster-Szenarien wirken häufig auf alle Systeme gleichzeitig
- Backups müssen dennoch Offsite repliziert werden

On-Prem-Backups sind in klassischen Rechenzentren nach wie vor verbreitet, müssen aber heute durch Offsite- oder Cloud-Kopien ergänzt werden, um auch gegen standortbezogene Risiken resilient zu sein.

6.2 Cloud-Backup-Architekturen

Cloud-Backups nutzen Speicher von Public-Cloud-Anbietern wie AWS, Azure oder Google Cloud.

Vorteile:

- geografisch verteilte Infrastruktur
- hohe Resilienz durch Cloud-Redundanz
- flexible Skalierung
- nutzungsabhängiges Kostenmodell
- einfache Offsite-Sicherung

Herausforderungen:

- Abhängigkeit vom Cloud-Anbieter
- Egress-Kosten bei der Wiederherstellung großer Datenmengen
- Sicherheitsanforderungen (z. B. Verschlüsselung, IAM, MFA)
- Shared-Responsibility-Modell
- mögliche Fehlkonfigurationen, die Daten exponieren

Cloud-Backups sind besonders geeignet für Organisationen, die keine zweite physische Standortlogik aufbauen wollen oder stark virtualisierte Workloads nutzen.

6.3 Hybrid-Backup-Architekturen

Hybrid-Architekturen kombinieren On-Prem-Storage mit cloudbasierten Backup-Zielen.

Vorteile:

- schnelle Backups und Restores lokal
- zusätzliche Sicherheit durch Cloud-Offsite-Kopie
- flexibel skalierbar
- Kosten steuerbar durch Mischung aus lokalem und Cloud-Speicher

Herausforderungen:

- höhere Komplexität
- unterschiedliche Backup-Mechanismen
- Governance-Probleme bei Berechtigungen und Identitäten
- Datenklassifizierung erforderlich (was darf wohin?)

Hybride Architekturen werden in der Praxis zur Standardlösung, da sie das Beste aus beiden Welten verbinden.

6.4 Air-Gapped und Immutable-Systeme in der Architektur

Air-Gap- und Immutable-Technologien können in **allen** Architekturvarianten integriert werden.

Air-Gap – physisch oder logisch getrennt:

- Tape-Systeme
- Offline-Storage
- ausgehängte Backup-Appliances

Immutable – schreibgeschützt:

- WORM-Dateisysteme
- immutable Cloud-Objektspeicher
- unveränderbare Snapshots

Moderne Resilienzarchitekturen kombinieren häufig **lokale Backups**, **Cloud-Backups** und **immutable Kopien**, um vielseitige Angriffsvektoren abzudecken.

6.5 Shared-Responsibility-Modell in der Cloud

Ein häufiges Missverständnis ist, dass Cloud-Anbieter automatisch die Datensicherung übernehmen.

In der Realität gilt:

- Der Cloud-Anbieter sichert die **Infrastruktur**.
- Der Kunde sichert **seine Daten, Konfigurationen und Zugänge**.

Dies wurde bereits in zahlreichen Fällen deutlich, etwa durch falsch konfigurierte AWS-S3-Buckets, gelöschte Cloud-Datenbanken oder kompromittierte Zugänge zu Cloud-Nutzerkonten.

6.6 Architekturentscheidungen und Risikoprofile

Backup-Architekturen sollten immer risikobasiert entwickelt werden:

- Welche Systeme sind geschäftskritisch?
- Welche RTO/RPO gelten?
- Wie hoch ist die Veränderungsrate der Daten?
- Welche Angriffsvektoren müssen ausgeschlossen werden?
- Welche geografischen Risiken existieren?

Keine Architektur ist „die beste“.

Resilienz bedeutet: Die Architektur passt zum Risiko – nicht umgekehrt.

6.7 Fazit

Backup-Architekturen sind die strategische Basis technischer Resilienz. Moderne Lösungen sind hybrid, cloudfähig, immutable und air-gapped. Organisationen, die ausschließlich auf eine einzelne Architektur setzen, riskieren im Ernstfall den Verlust ihrer Wiederherstellungsfähigkeit.

Kapitel 7 – Disaster Recovery: Grundlagen, RTO, RPO und Strategien

Während Backups primär die **Datenbasis** absichern, beschäftigt sich Disaster Recovery (DR) mit der **Wiederherstellung kompletter IT-Systeme** nach einem schwerwiegenden Ausfall. DR ist damit die operative Fähigkeit, Systeme und Dienste in einer definierten Zeit und mit einem definierten Datenverlust wieder bereitzustellen. Es ist der technische Motor von Business Continuity.

7.1 Was ist Disaster Recovery?

Disaster Recovery umfasst alle Maßnahmen und Prozesse, um nach einem schwerwiegenden Ereignis:

- Daten wiederherzustellen
- Systeme neu aufzubauen
- Dienste wieder in Betrieb zu nehmen

Typische Auslöser eines DR-Falls sind:

- Ransomware-Angriffe
- Ausfall ganzer Rechenzentren
- schwerwiegende Cloud-Fehlkonfigurationen
- Verlust zentraler Storage-Systeme
- Stromausfälle oder physische Schäden
- interne Sabotage oder technische Großstörungen

DR unterscheidet sich vom Backup darin, dass es nicht nur um Daten, sondern um ein **funktionsfähiges Gesamtsystem** geht.

7.2 Abgrenzung zu Business Continuity Management (BCM)

Ein häufiges Missverständnis ist die Gleichsetzung von DR und BCM.

Disaster Recovery (DR)	Business Continuity Management (BCM)
technische Wiederherstellung	organisatorische Betriebsfortführung
Fokus: IT-Systeme	Fokus: Geschäftsprozesse
Ziel: Systeme wieder lauffähig machen	Ziel: Geschäft weiterführen
RTO/RPO	BIA (Business Impact Analysis)
Recovery-Pläne	Notfallpläne & Ausweichprozesse

Ein robustes BCM benötigt funktionierendes DR. DR kann ohne BCM nur einen Teil der Gesamtresilienz leisten.

7.3 Recovery Time Objective (RTO)

Das **RTO** definiert, wie viel Zeit zwischen dem Ausfall eines Systems und seiner vollständigen Wiederherstellung maximal vergehen darf.

Beispiele:

- RTO 4 Stunden → System muss sehr schnell wieder verfügbar sein
- RTO 48 Stunden → größere Downtime tolerierbar
- RTO 0 (Zero Downtime) → erfordert redundante Architekturen (z. B. Active/Active)

RTO beeinflusst maßgeblich:

- Kosten
- Architekturkomplexität
- technische Anforderungen
- DR-Strategie

7.4 Recovery Point Objective (RPO)

Das **RPO** gibt an, wie viel Datenverlust tolerierbar ist.

Beispiele:

- RPO 0 → keine Daten dürfen verloren gehen
- RPO 15 Minuten → maximal 15 Minuten an Datenmodifikationen dürfen fehlen
- RPO 24 Stunden → tägliche Sicherungen ausreichend

RPO ist abhängig von:

- Datenveränderungsrate
- Transaktionsvolumen
- Backup-Intervallen
- Replikationsmechanismen

RTO = Zeit
RPO = Datenverlust

Beide Metriken bestimmen gemeinsam die DR-Anforderungen.

7.5 DR-Strategien

Organisationen wählen DR-Strategien entsprechend ihrer RTO/RPO-Ziele und ihres Budgets.

Cold Standby

- Systeme sind ausgeschaltet
- Daten werden regelmäßig kopiert
- Wiederherstellung dauert am längsten
- Günstigste Variante

Warm Standby

- Systeme stehen bereit, aber nicht aktiv
- Konfiguration aktuell
- Datenreplikation zeitversetzt
- mittlere RTO/RPO

Hot Standby

- nahezu vollständige Kopie eines Systems
- Recovery innerhalb kurzer Zeit möglich
- System meist bereits vorinstalliert
- kostenintensiver

Active/Passive

- aktives System + passives Ersatzsystem
- Umschalten im Fehlerfall

Active/Active

- beide Systeme gleichzeitig produktiv
- maximale Verfügbarkeit
- höchste Kosten & Komplexität

Multi-Cloud DR

- Systeme laufen in zwei unabhängigen Cloud-Umgebungen
- schützt gegen Cloud-Anbieter-Ausfälle
- hoher Test- und Abstimmungsaufwand

7.6 Abhängigkeiten und Wiederherstellungsreihenfolgen

In der Praxis scheitern viele DR-Pläne an unbekannten Abhängigkeiten:

- Datenbanken benötigen Storage, Schlüssel, Dienste
- Identitätsdienste (z. B. Active Directory) müssen vor Applikationen wiederhergestellt werden
- DNS oder IAM müssen verfügbar sein, bevor Systeme erreichbar sind
- Applikationen sind auf Middleware angewiesen

Eine fehlerhafte Reihenfolge macht DR oft wirkungslos.

7.7 Dokumentation als Erfolgsfaktor

Ein DR-Plan ist nur so gut wie seine Dokumentation:

- Wiederherstellungsschritte
- Reihenfolgen
- Rollen & Verantwortlichkeiten
- verwendete Tools
- Zugangsdaten
- Netzwerkpfade
- Notfallkontakte

Fehlende oder veraltete Dokumentation gehört zu den häufigsten DR-Fehlern.

7.8 Fazit

Disaster Recovery ist die Fähigkeit, Systeme schnell und kontrolliert wiederherzustellen.

Ohne klare RTO/RPO, passende DR-Strategie und gute Dokumentation gibt es keine technische Resilienz.

Kapitel 8 – Notfalltests: Formen, Methoden, Ziele

Notfalltests sind der praktische Beweis, dass Backup- und Disaster-Recovery-Konzepte im Ernstfall funktionieren. Ohne regelmäßig getestete Wiederherstellungsprozesse bleibt technische Resilienz theoretisch. Erst Tests zeigen, ob die Verfahren, Werkzeuge, Dokumentationen und Menschen wirklich in der Lage sind, eine Störung zu bewältigen.

In der Praxis zeigt sich:

Ein Backup, das nicht getestet wurde, ist kein Backup.

8.1 Zweck und Bedeutung von Notfalltests

Notfalltests dienen dazu:

- den **Ernstfall zu simulieren**, bevor er eintritt
- Schwachstellen in Backup-, DR- und Wiederherstellungsprozessen zu identifizieren
- Rollen und Abläufe im Team zu üben
- Dokumentationen zu optimieren
- Reaktionszeiten und technische Grenzen realistisch einzuschätzen

Sie schaffen Vertrauen in die Wiederherstellungsfähigkeit der Organisation und sind fester Bestandteil aller gängigen Standards (ISO 27001, BSI IT-Grundschutz, NIST SP 800-34).

8.2 Typen von Notfalltests

Es gibt verschiedene Testformen, die sich in Aufwand, Realismus und Risiko unterscheiden.

1. Tabletop-Übungen (Planspiele)

Eine rein **theoretische** Simulation:

- Beteiligte diskutieren Szenarien
- Rollen werden durchgespielt
- Entscheidungen werden analysiert
- keine Systeme werden verändert

Geeignet für: erste Tests, Sensibilisierung, Eskalationspfade.

2. Technical Dry Run

Ein „Probelauf“ ohne vollständiges Umschalten:

- Testen einzelner Schritte des DR-Plans
- Wiederherstellen einzelner Datenbanken oder VMs
- Validierung der Dokumentation
- geringe Auswirkungen auf produktive Systeme

Geeignet für: schrittweise Verbesserung, Fehlersuche, Routine.

3. Vollständiger Failover-Test (Full Failover)

Reale Umschaltung der Systeme in die DR-Umgebung:

- produktive oder produktionsnahe Umgebung
- End-to-End-Prüfung aller Abhängigkeiten
- Messung von RTO & RPO
- sehr hoher Erkenntnisgewinn

Herausfordernd:

- erhöhter Aufwand
- potenzielle Risiken für Produktivbetrieb
- benötigt gute Planung

4. Blackhole-Tests / Controlled Outage

Simulation eines plötzlichen Ausfalls, z. B.:

- gezieltes Abschalten von Systemen
- Unterbrechung von Netzwerkpfaden
- Ausfall von Storage

Diese Tests sind Teil von **Chaos Engineering** (z. B. Netflix Simian Army, Azure Chaos Studio, AWS Fault Injection Service).

Ziel ist: Schwachstellen in realitätsnahen Szenarien zu finden.

8.3 Erfolgskriterien für Notfalltests

Ein Test ist nur dann wertvoll, wenn:

- Ziele vorher definiert wurden
- Dokumentation erstellt oder aktualisiert wird
- RTO & RPO gemessen werden
- Lessons Learned dokumentiert und umgesetzt werden
- der Test reproduzierbar ist

Tests ohne Auswertung sind reine Übungen ohne Lerneffekt.

8.4 Häufige Probleme bei Notfalltests

In der Praxis scheitern Tests oft an:

- fehlenden Verantwortlichkeiten
- veralteten DR-Plänen
- mangelnder Testtiefe
- fehlender Testumgebung
- unvollständigen Backups oder beschädigten Kettengliedern
- fehlendem Rollback-Plan
- Angst vor Störung des Produktivsystems

Viele Organisationen testen nur formell, nicht realistisch – und stehen im Ernstfall vor Überraschungen.

8.5 Integration in den Resilienzprozess

Notfalltests müssen Teil eines zyklischen Resilienzprozesses sein:

1. Planen
2. Testen
3. Dokumentieren
4. Bewerten
5. Anpassen
6. Wiederholen

Dies entspricht dem PDCA-Modell (Plan-Do-Check-Act) und dem OODA-Zyklus (Observe–Orient–Decide–Act), die organisatorische und technische Resilienz zusammenführen.

8.6 Fazit

Resilienz entsteht nicht durch Backups oder DR-Pläne – sondern dadurch, dass sie funktionieren, wenn sie gebraucht werden. Notfalltests sind die Brücke zwischen Theorie und Realität.

Kapitel 9 – Typische Fehler & Best Practices technischer Resilienz

Technische Resilienzmaßnahmen scheitern in der Praxis häufig nicht an Technologie, sondern an falschen Annahmen, ungeeigneten Prozessen oder mangelnder Disziplin. Dieses Kapitel fasst typische Fehler zusammen und zeigt gleichzeitig Best Practices auf, die Organisationen widerstandsfähiger machen.

9.1 Typische Fehler bei Backups

1. Fehlende oder unvollständige Backups

Viele Organisationen sichern nur Daten, nicht aber Konfigurationen, Metadaten, Schlüsselmaterial oder Systemzustände. Ein Restore scheitert dann, weil:

- Dienste nicht starten
- Lizenzschlüssel fehlen
- TLS-Zertifikate nicht gesichert wurden
- Konfigurationsdateien fehlen

Backups müssen vollständig sein.

2. Snapshots werden als Backups interpretiert

Snapshots sind nützlich, aber:

- hängen am Storage-System
- sind nicht vor Ransomware geschützt
- bieten keine langfristige Aufbewahrung

→ Sie sind Ergänzung, kein Ersatz.

3. Backup-Ketten sind beschädigt

Inkrementelle Backups bilden Ketten. Fällt ein Glied aus, ist der gesamte Restore gefährdet.

Häufige Ursachen:

- Korruption

- fehlende Bereinigung
- mangelndes Monitoring

Best Practice: regelmäßige Konsistenzprüfungen.

4. Backups sind nicht isoliert

„Online verbundene Backups“ sind bei modernen Ransomware-Angriffen besonders gefährdet.

Fehler:

- Backup-Server im gleichen AD wie Produktionssysteme
- Admin-Konten ohne Least Privilege
- Backups auf Netzlaufwerken ohne Write-Protection

9.2 Typische Fehler bei Disaster Recovery

1. Unklare oder unrealistische RTO/RPO

RTO 1 Stunde bei täglichem Backup? RPO 0 bei Systemen ohne Replikation?

Fehlende Abstimmung zwischen **IT und Fachbereichen** führt zu unrealistischen Anforderungen.

2. Fehlerhafte Wiederherstellungsreihenfolge

Viele DR-Pläne scheitern daran, dass Abhängigkeiten nicht berücksichtigt wurden:

- DNS und Active Directory müssen vor Applikationen verfügbar sein
- Storage muss vor VMs verfügbar sein
- IAM muss vor Cloud-Ressourcen funktionieren

3. Fehlende Dokumentation

Klassische Szenarien:

- Notfallhandbuch existiert nicht
- Verantwortlichkeiten sind unklar
- technische Schritte fehlen oder sind veraltet

Im Ernstfall führt das zu Chaos statt Recovery.

4. DR-Umgebung ist nicht identisch zur Produktivumgebung

Unterschiede in:

- Versionen
- IP-Adressräumen
- Zertifikaten
- Netzwerksegmenten

→ führen zu Wiederanlaufproblemen.

9.3 Typische Fehler bei Notfalltests

1. Tests ohne Zielsetzung

„Wir testen einfach mal.“ Ergebnis: Kein Lerneffekt.

2. Tests ohne dokumentierte Ergebnisse

Nichts wurde analysiert, niemand zieht Konsequenzen – somit kein Resilienzgewinn.

3. Angst vor Tests

Viele Organisationen testen nicht aus Sorge vor Betriebsunterbrechungen. Das führt zu einer gefährlichen Scheinsicherheit.

9.4 Best Practices technischer Resilienz

1. Zero-Trust-Prinzipien auch für Backups

- getrennte Administratorrollen
- Multi-Faktor-Authentifizierung
- Netzwerksegmentierung
- Immutable Medien

2. Regelmäßige Restore-Tests

Minimale Erwartungshaltung:

- monatlicher Restore-Test
- jährlicher Full-Failover-Test
- vierteljährlicher Tabletop-Test

3. Nutzung von Automatisierung

Automatisiert werden sollten:

- Backup-Jobs
- Monitoring
- Konsistenzprüfungen
- DR-Startprozeduren

Automatisierung reduziert menschliche Fehler.

4. Dokumentation als lebendes Artefakt

Ein DR-Plan ist keine statische Datei. Er muss:

- regelmäßig aktualisiert werden
- Bestandteil des Change-Managements sein
- mit Lessons Learned wachsen

5. Kombination redundanter Technologien

Resilienz entsteht durch Kombination:

- lokale Backups + Cloud
- Snapshots + Vollbackups
- Warm Standby + Immutable Offsite
- DR + BCM

9.5 Fazit

Technische Resilienz scheitert selten an fehlender Technologie – sie scheitert an fehlender Disziplin, fehlender Dokumentation und ungetesteten Annahmen. Best Practices sind Standardisierungs-, Sicherheits- und Lernmechanismen zugleich.

Kapitel 10 – Zusammenfassung & Lernkernpunkte

Dieses letzte Kapitel fasst die wesentlichen Erkenntnisse der Sitzung kompakt zusammen und stellt die zentralen Lernpunkte dar, die Studierende für Prüfungsvorbereitung, Praxisanwendung und weitere Sitzungen mitnehmen sollen. In technischer Resilienz geht es nicht nur um das Vorhandensein von Sicherungsmaßnahmen, sondern um ihre **Wirksamkeit**, **Konsistenz** und **Testbarkeit**.

10.1 Rückblick auf die drei Säulen technischer Resilienz

Die Sitzung hat drei technische Kernkomponenten beleuchtet:

1. Backups – die Datenbasis der Resilienz

Backups sind die letzte Verteidigungslinie gegen Datenverlust durch:

- Cyberangriffe
- Hardwarefehler
- menschliche Fehler
- logische Datenkorruption

Sie müssen **isoliert**, **manipulationssicher** und **regelmäßig getestet** sein.

2. Disaster Recovery – das Wiederherstellungsfundament

Disaster Recovery ermöglicht die Wiederherstellung kompletter Systeme nach einem schweren Ausfall.

Wesentliche Elemente sind:

- klare RTO/RPO
- geeignete DR-Strategien (Cold, Warm, Hot, Active/Active)
- konsistente Systemabhängigkeiten
- realistische Dokumentation
- reproduzierbare Wiederanlaufprozesse

3. Notfalltests – der Praxisnachweis

Erst Tests zeigen, ob:

- Backups funktionieren
- DR-Pläne korrekt sind
- Wiederherstellungszeiten erreicht werden können
- Teams, Prozesse und Dokumentationen im Ernstfall zusammenwirken

Ohne Tests bleibt Resilienz Theorie.

10.2 Die wichtigsten Risiken, die technische Resilienz adressiert

Technische Resilienzmaßnahmen schützen vor:

- Ransomware
- versehentlichen oder böswilligen Löschungen

- Speicher- und Hardwarefehlern
- Softwarefehlern
- Cloud-Fehlkonfigurationen
- Standortausfällen

Backups sichern Daten. DR sichert Systeme. Tests sichern Vertrauen.

10.3 Kerngedanken zur Prüfungsvorbereitung

Studierende sollten insbesondere verstehen:

- Unterschiede zwischen Backup, Archiv und Redundanz
- die 3-2-1-1-0-Regel und ihre praktische Bedeutung
- RTO und RPO und wie sie definiert werden
- Unterschiede der DR-Strategien
- warum Snapshots keine Backups sind
- welche Testformen es gibt und welchen Zweck sie erfüllen
- typische Fehler und wie man sie vermeidet

10.4 Verbindung zur Gesamtvorlesung

Dieses Kapitel schließt den ersten Teil der **technischen Resilienzmaßnahmen** ab und bildet den Übergang zu:

- Resilienz in verteilten Systemen
- Cyber-Resilienz in Cloud-Umgebungen
- Identitätsresilienz
- Monitoring- und Detection-Resilienz
- Recovery im Kontext moderner Security-Architekturen

Die Studierenden sollten nun verstehen, dass technische Resilienz **ganzheitlich** gedacht werden muss und mehrere Ebenen umfasst.

10.5 Fazit

Technische Resilienz ist kein Produkt, sondern ein Fähigkeitssystem. Es besteht aus Sicherung, Wiederanlauf und Erprobung – und jede Lücke gefährdet das Gesamtsystem.

Backups retten Daten. Disaster Recovery rettet Systeme. Tests retten den Betrieb.

Zusammen sichern sie die Überlebensfähigkeit digitaler Organisationen.

Prüfungsrelevante Leitfragen – Sitzung 7

Technische Resilienzmaßnahmen I: Backup-Strategien, DR & Notfalltests

1. Warum sind Backups eine zentrale Säule der technischen Resilienz?

- Welche realen Bedrohungen adressieren Backups?
- Warum gelten sie als „letzte Verteidigungslinie“?
- Was unterscheidet moderne Bedrohungen (z. B. Ransomware) von klassischen Ausfallszenarien?

2. Worin unterscheiden sich Backup, Archiv und Redundanz grundlegend?

- Welche Rolle spielt jedes Konzept in der Resilienzarchitektur?
- Warum können diese Konzepte einander nicht ersetzen?
- Nenne Beispiele für typische Missverständnisse in der Praxis.

3. Was beschreibt die 3-2-1-1-0-Regel und warum ist sie heute Standard?

- Was bedeuten die einzelnen Zahlen?
- Warum ist „immutable“ oder „air-gapped“ heute unverzichtbar?
- Was bedeutet die „0“ am Ende und warum ist sie kritisch für Resilienz?

4. Welche Backup-Typen gibt es und worin unterscheiden sie sich?

- Erkläre Voll-, inkrementelle und differenzielle Backups.
- Warum sind Snapshots *keine* Backups?
- Welcher Backup-Typ eignet sich für häufige Veränderungen?

5. Welche Vor- und Nachteile haben On-Prem-, Cloud- und Hybrid-Backup-Architekturen?

- Welches Modell bietet welche Art von Schutz?
- Welche Risiken existieren jeweils (z. B. Abhängigkeiten, Kosten, Governance)?
- Was bedeutet „Shared Responsibility“ im Cloud-Kontext?

6. Was ist Disaster Recovery und wie unterscheidet es sich vom Business Continuity Management?

- Was ist der Fokus von DR?
- Was ist der Fokus von BCM?
- Wie hängen beide Konzepte zusammen?

7. Was bedeuten RTO und RPO?

- definiere beide Begriffe präzise
- gib typische Beispiele („RTO 4h“, „RPO 15min“)
- wie beeinflussen RTO und RPO die DR-Strategie?

8. Welche DR-Strategien gibt es und was unterscheidet sie?

- Cold, Warm, Hot, Active/Passive, Active/Active
- Welche Vor- und Nachteile haben die einzelnen Strategien?
- Wie hängt die Kostenstruktur mit RTO/RPO zusammen?

9. Warum sind Notfalltests unverzichtbar?

- Welche Testarten gibt es? (Tabletop, Dry Run, Full Failover, Chaos Engineering)
- Warum gilt: „Ein ungetestetes Backup ist kein Backup“?
- Welche Ziele und Messgrößen sollten Tests haben?

10. Welche typischen Fehler gefährden technische Resilienz?

- Was geht häufig bei Backups schief?
- Warum scheitern DR-Pläne in der Praxis?
- Welche organisatorischen Ursachen sind häufig?

- Wie lassen sich diese Fehler vermeiden?

Übungsanleitung – Sitzung 7

„Plan the Worst Day" – Backup-, DR- und Notfalltest-Konzept entwickeln

Ziel der Übung Die Studierenden sollen anhand eines realitätsnahen Szenarios ein vollständiges technisches Resilienzkonzept entwickeln.

Dabei wenden sie die in der Sitzung besprochenen Inhalte praktisch an:

- Backup-Strategien (3-2-1-1-0, Backup-Typen, Offsite, Immutable/Air-Gap)
- DR-Strategien (RTO/RPO, Warm/Hot/Active-Passive, Wiederanlaufreihenfolge)
- Notfalltest-Planung (Testformen, Metriken, Lessons Learned)

Die Übung verbindet **Analyse**, **Design**, **Abstimmung** und **Präsentation**.

Szenario Sie sind das frisch zusammengestellte Resilienzteam des **Rechenzentrums der Hochschule Mainz**.

Am vergangenen Wochenende wurde das Hochschulnetzwerk durch einen kombinierten **Ransomware- und Datenbankkorruptionsvorfall** erheblich gestört – glücklicherweise nur simuliert.

Ihr Auftrag:

Entwickeln Sie innerhalb von 90 Minuten ein vollständiges technisches Resilienzkonzept für die wichtigsten IT-Services der Hochschule.

Die zentralen Systeme sind:

1. Lernplattform (Moodle)
2. Identity Management / Active Directory
3. E-Mail & Collaboration
4. Prüfungsdatenbank (examinare SQL)
5. Fileservices für Studierende & Mitarbeitende
6. Hochschul-Webseite inkl. CMS

Aufgabenübersicht (für 90 Minuten)

Teil 1 – Backup-Konzept entwickeln (ca. 30 Minuten)

Erarbeiten Sie für die oben genannten Systeme ein Backup-Design, das folgende Fragen beantwortet:

1. Welche Daten müssen gesichert werden?
2. Wie oft? (Backup-Frequenz)
3. Welcher Backup-Typ ist geeignet?
   - Vollbackup?
   - Differenziell?
   - Inkrementell?
   - Snapshots (zur Ergänzung)?
4. Wie setzen Sie die **3-2-1-1-0-Regel** um?

5. Wo liegt die Offsite-Kopie?
6. Wie schützen Sie das Backup vor Ransomware? (Air-Gap, Immutable)
7. Welche Retention-Zeiten werden definiert?

Ergebnis: Eine Tabelle oder ein strukturiertes Schema pro System.

Teil 2 – Disaster-Recovery-Plan entwerfen (ca. 30 Minuten)

Definieren Sie:

1. **RTO und RPO** für jedes der sechs Kernsysteme
2. Welche DR-Strategie eingesetzt wird (Cold, Warm, Hot, Active/Passive, Active/Active)
3. Welche Abhängigkeiten zu berücksichtigen sind (Beispiel: AD vor E-Mail, DNS vor allem)
4. Die Wiederherstellungsreihenfolge
5. Welche Infrastrukturelemente zwingend zuerst funktionsfähig sein müssen (z. B. Storage, Netzwerk, IAM)

Ergebnis: Ein diagrammatischer DR-Plan + tabellarische Priorisierung.

Teil 3 – Notfalltest-Konzept entwickeln (ca. 30 Minuten)

Erarbeiten Sie einen realistischen Testplan für die nächsten 12 Monate:

1. Welche Testarten setzen Sie ein?
   - Tabletop
   - Technical Dry Run
   - Full Failover
   - Chaos Test (Blackhole-Test)
2. Wie oft soll getestet werden?
3. Nach welchen Metriken wird der Erfolg bewertet?
   - RTO-Abweichung
   - RPO-Erreichung
   - Datenintegrität
   - Anzahl der gefundenen Schwachstellen
4. Wie wird dokumentiert?
5. Wie werden Lessons Learned umgesetzt?

Ergebnis: Ein Jahres-Testplan inkl. Erfolgsindikatoren.

Bibliografie